

VULNERABILITY ASSESSMENT REPORT

Website: <https://demo.testfire.net/>

Date: 21 May 2026
Prepared by: Anay Nayak

DISCLAIMER

This assessment was conducted passively and ethically in a read-only capacity. No exploitation, brute force, login bypass, or denial-of-service techniques were used.

demo.testfire.net is a publicly available, intentionally vulnerable demonstration site provided by IBM for security education purposes.

This report is intended for educational use only.



EXECUTIVE SUMMARY

This report presents the findings of a passive, read-only security assessment conducted on demo.testfire.net.

The assessment identified 6 security weaknesses including missing security headers, exposed server information and unprotected session cookies.

No exploitation or active attacks were performed.

All findings are based on publicly visible information and response headers only.

Total findings: 8

High risk: 4

Medium risk: 3

Low risk: 1



SCOPE AND METHODOLOGY

Target: demo.testfire.net

IP Address: 65.61.137.117

Date: 21 May 2026

securityheaders.com	Grade: F
SSL Labs (Qualys)	Grade: B
MDN HTTP Observatory	Score: 10/100 (F)
Chrome DevTools	Header & Cookie inspection

What Was Done	What Was NOT Done
HTTP header analysis	Login bypass
SSL/TLS certificate review	Brute force attacks
Cookie flag inspection	Exploitation
Passive traffic observation	Denial of service

FINDINGS SUMMARY TABLE

Finding	Source	Risk
Missing Content-Security-Policy	All 3 tools	High
Missing Strict-Transport-Security	All 3 tools	High
Missing X-Frame-Options	All 3 tools	High
No HTTPS Redirect	Observatory	High
Missing X-Content-Type-Options	All 3 tools	Medium
Missing Referrer-Policy	All 3 tools	Medium
Weak SSL — TLS 1.0/1.1 Supported	SSL Labs	Medium
Missing Permissions-Policy	securityheaders.com	Low

Title: Missing Content-Security-Policy (CSP)

Risk Level: HIGH | Score Impact: -25

What Was Found:

No Content-Security-Policy header present.
Confirmed by securityheaders.com, SSL Labs,
and MDN Observatory (score penalty: -25).

Why It Matters:

Without CSP, attackers can inject malicious scripts into the page (XSS attacks), stealing user data, passwords, and session tokens.

Fix:

Content-Security-Policy: default-src 'self'

Evidence:

Site:

<https://demo.testfire.net/>

IP Address:

65.61.137.117

Report Time:

21 May 2026 17:05:12 UTC

Headers:

✖ Strict-Transport-Security

✖ Content-Security-Policy

✖ X-Frame-Options

✖ X-Content-Type-Options

✖ Referrer-Policy

✖ Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately:

Start Now

Content Security Policy (CSP)	-25 ✖	Content Security Policy (CSP) header not implemented	Implement one, see MDN's Content Security Policy (CSP) documentation .
---	-------	--	--

Title: Missing Strict-Transport-Security (HSTS)

Risk Level: HIGH | Score Impact: -20

What Was Found:

No Strict-Transport-Security header found.

Confirmed by all three scanning tools.

Why It Matters:

Browsers may load the site over unencrypted HTTP.

Attackers on the same network can intercept and read all traffic (man-in-the-middle attack).

Fix:

Strict-Transport-Security: max-age=31536000; includeSubDomains

Evidence:



Security Report Summary

Site:	https://demo.testfire.net/
IP Address:	65.61.137.117
Report Time:	21 May 2026 17:05:12 UTC
Headers:	✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
Advanced:	Ouch, you should work on your security posture immediately: Start Now

<u>Strict Transport Security (HSTS)</u>	-20 ✖	Strict-Transport-Security header not implemented.	Add HSTS. Consider rolling out with shorter periods first (as suggested on https://hstspreload.org/).
---	-------	--	---

Title: Missing X-Frame-Options
Risk Level: HIGH | **Score Impact:** -20

What Was Found:
No X-Frame-Options header present.
Confirmed by all three scanning tools.

Why It Matters:
The site can be embedded invisibly inside another webpage. Attackers trick users into clicking things they didn't intend to — known as Clickjacking.

Fix:
X-Frame-Options: DENY

Evidence:



Security Report Summary

Site:	https://demo.testfire.net/
IP Address:	65.61.137.117
Report Time:	21 May 2026 17:05:12 UTC
Headers:	✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
Advanced:	Ouch, you should work on your security posture immediately: Start Now

X-Frame-Options

-20 ✖

X-Frame-Options (XFO) header not implemented.

Implement frame-ancestors CSP.

Title: No Automatic HTTPS Redirect

Risk Level: HIGH | Score Impact: -20

What Was Found:

The site does not redirect HTTP traffic to HTTPS.
Identified by MDN HTTP Observatory.

Evidence:

<u>Redirection</u>	-20 ❌	Does not redirect to an HTTPS site.	Redirect to the same host on HTTPS first, then redirect to the final host on HTTPS.
--------------------	-------	-------------------------------------	---

Why It Matters:

Users who type the URL without "https://" will connect over an unencrypted connection. Their login credentials and data can be intercepted.

Fix:

Configure server to redirect all HTTP requests:
HTTP 301 redirect → https://demo.testfire.net

Title: Missing X-Content-Type-Options

Risk Level: MEDIUM | Score Impact: -5

What Was Found:

No X-Content-Type-Options header present.

Why It Matters:

Browsers may misread file types, allowing attackers to disguise malicious files as safe content (MIME-type sniffing attack).

Fix:

X-Content-Type-Options: nosniff

Evidence:

Security Report Summary



Site:

https://demo.testfire.net/

IP Address:

65.61.137.117

Report Time:

21 May 2026 17:05:12 UTC

Headers:

✖ Strict-Transport-Security

✖ Content-Security-Policy

✖ X-Frame-Options

✖ X-Content-Type-Options

✖ Referrer-Policy

✖ Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately:

Start Now

X-Content-Type-Options

-5 ✖

X-Content-Type-Options header not implemented.

Set to nosniff.

Title: Missing Referrer-Policy

Risk Level: MEDIUM

What Was Found:

No Referrer-Policy header present.
Flagged by securityheaders.com and Observatory.

Why It Matters:

When users click links, their full URL (including any sensitive parameters) is sent to external sites, leaking internal navigation paths and user data.

Fix:

Referrer-Policy: strict-origin-when-cross-origin

Evidence:

Site:

<https://demo.testfire.net/>

IP Address:

65.61.137.117

Report Time:

21 May 2026 17:05:12 UTC

Headers:

✖ Strict-Transport-Security

✖ Content-Security-Policy

✖ X-Frame-Options

✖ X-Content-Type-Options

✖ Referrer-Policy

✖ Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately:

Start Now

Referrer Policy

-

Referrer-Policy header not implemented.

Set to strict-origin-when-cross-origin at a minimum.

Title: Weak SSL/TLS — Outdated Protocol Support

Risk Level: MEDIUM

What Was Found:

SSL Labs gave an overall grade of B due to:

- Weak Diffie-Hellman (DH) key exchange parameters
- TLS 1.0 and TLS 1.1 still supported
- TLS 1.3 not supported
- No Post-Quantum Cryptography (PQC) support

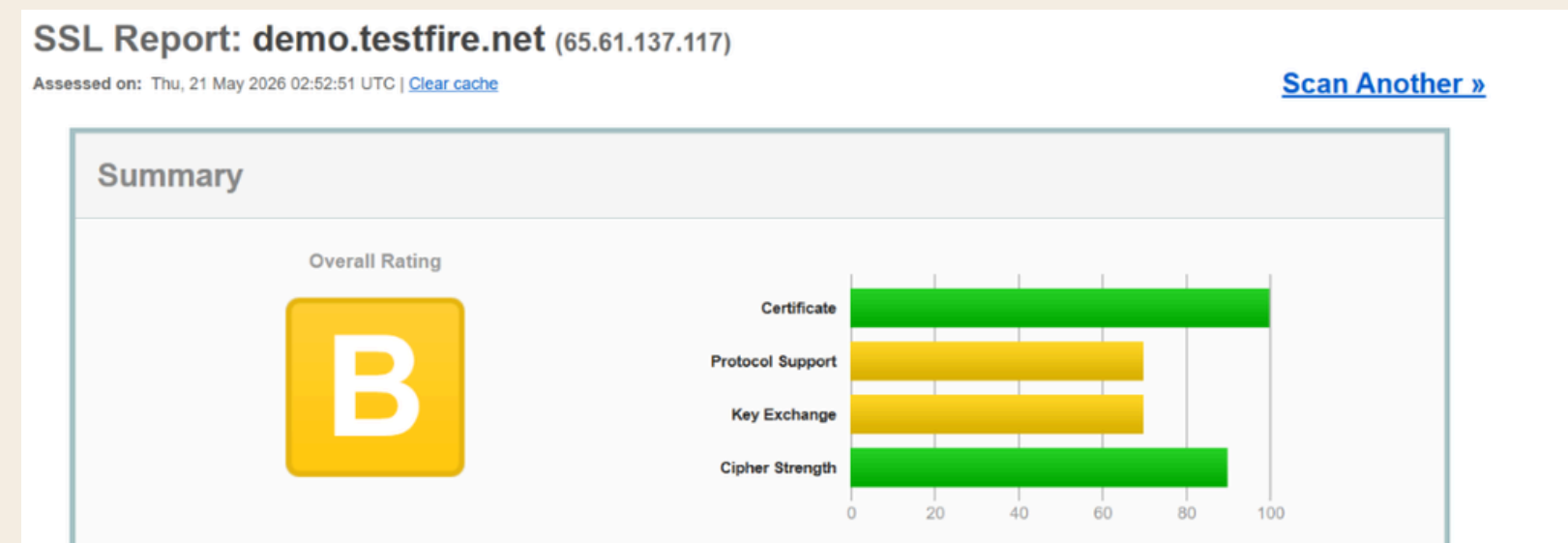
Why It Matters:

TLS 1.0 and 1.1 are deprecated and have known vulnerabilities. Attackers can exploit weak DH parameters to decrypt encrypted traffic.

Fix:

- Disable TLS 1.0 and TLS 1.1 entirely
- Enable TLS 1.3
- Use DH key size of at least 2048-bit

Evidence:



Title: Missing Permissions-Policy
Risk Level: LOW

What Was Found:
No Permissions-Policy header present.
Flagged by securityheaders.com.

Why It Matters:
Without this header, the browser grants full access to device features (camera, microphone, location) to any embedded scripts without restriction.

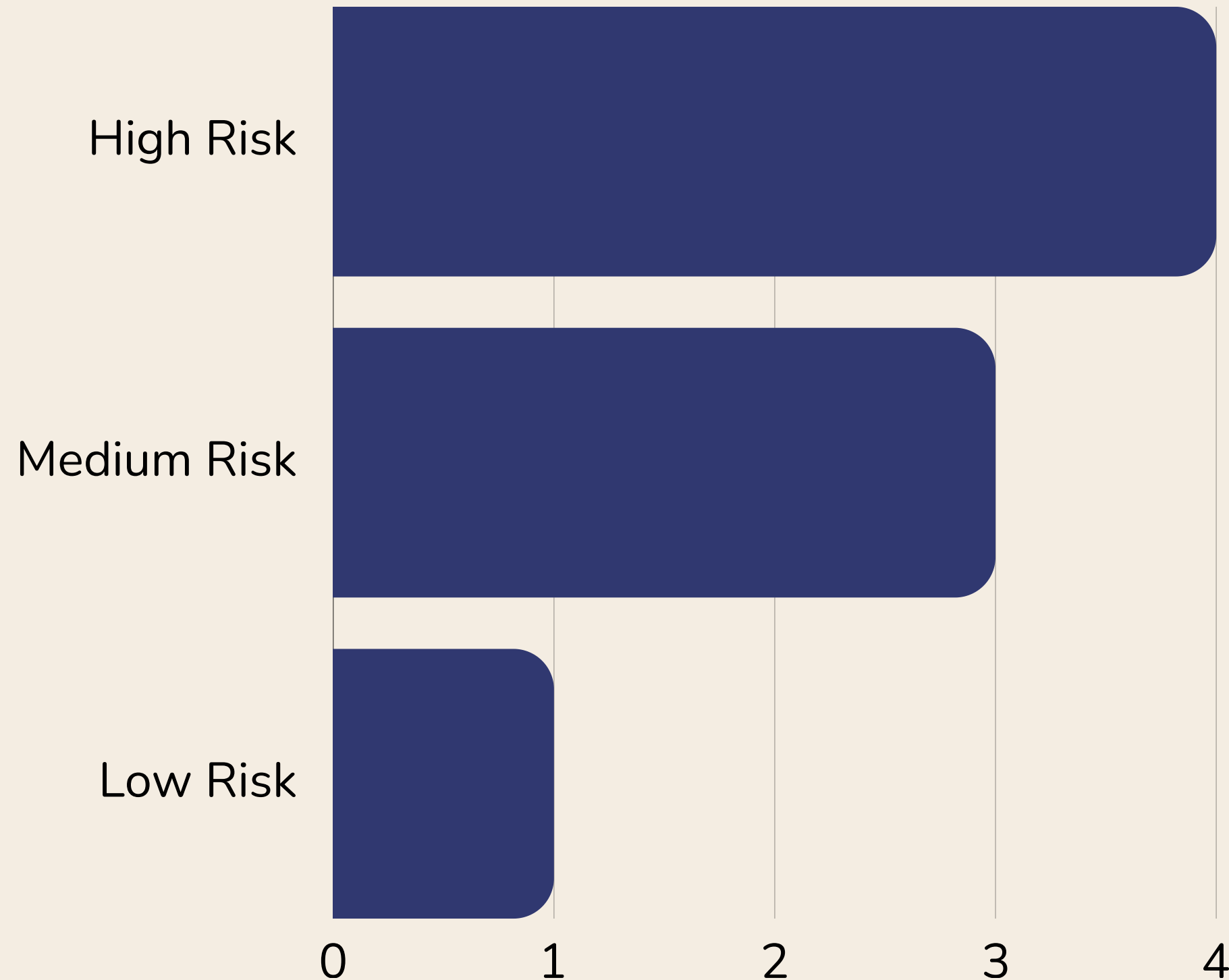
Fix:
Permissions-Policy: geolocation=(), microphone=(), camera=()

Evidence:

Security Report Summary

Site:	https://demo.testfire.net/
IP Address:	65.61.137.117
Report Time:	21 May 2026 17:05:12 UTC
Headers:	✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
Advanced:	Ouch, you should work on your security posture immediately: Start Now

RISK ANALYSIS SUMMARY



Overall Security Grade: F (securityheaders.com)

SSL Grade: B (Qualys SSL Labs)

Observatory Score: 10/100

SECURITY RECOMMENDATION

IMMEDIATE (High Risk)

1. Add all missing security headers in one server config change — fixes findings #1, #2, #3, #5, #6, #8
2. Enable forced HTTPS redirect — fixes finding #4

SHORT TERM (Medium Risk)

3. Disable TLS 1.0 and 1.1, enable TLS 1.3
Upgrade Diffie-Hellman parameters to 2048-bit

Note: Findings #1, #2, #3, and #4 received the maximum penalty score from Observatory (-20 each). These must be treated as urgent priorities.